informe de vulnerabilidades de RSA learn

Sitio: http://localhost:3000

Generado a mar, 20 oct 2026 01:39:20

ZAP Versión: 2.17.0

ZAP by Checkmarx

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	0
Medio	3
Bajo	0
Informativo	0

Insights

Level	Razón	Site	Descripción	Statistic
Información	Informativo	http://localhost:3000	Percentage of responses with status code 2xx	11 %
Información	Informativo	http://localhost:3000	Percentage of responses with status code 3xx	70 %
Información	Informativo	http://localhost:3000	Percentage of responses with status code 4xx	18 %
Información	Informativo	http://localhost:3000	Percentage of endpoints with content type text/css	42 %
Información	Informativo	http://localhost:3000	Percentage of endpoints with content type text /html	57 %
Información	Informativo		Percentage of	100 %

		http://localhost:3000	endpoints with method GET	
Información	Informativo	http://localhost:3000	Count of total endpoints	7

Alertas

Nombre	Nivel de riesgo	Número de Instancias
CSP: Failure to Define Directive with No Fallback	Medio	2
CSP: script-src unsafe-inline	Medio	3
CSP: style-src unsafe-inline	Medio	3

Detalles de la Alerta

Medio	CSP: Failure to Define Directive with No Fallback
Descripción	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://localhost:3000/robots.txt
Nombre del Nodo	http://localhost:3000/robots.txt
Método	GET
Ataque	
Evidencia	default-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:3000/sitemap.xml
Nombre del Nodo	http://localhost:3000/sitemap.xml
Método	GET
Ataque	
Evidencia	default-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instancia	2
Solución	Asegúrese de que su servidor web, servidor de aplicación, balanceador de carga, etc. está configurado apropiadamente para establecer la cabecera de Política de Seguridad de Contenido.
Referencia	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medio	CSP: script-src unsafe-inline
Descripción	Content Security Policy (CSP) es una capa de seguridad añadida que ayuda a detectar y mitigar ciertos tipos de ataques. Incluyendo (pero no limitado a) Cross Site Scripting (XSS), y ataques de inyección de datos. Estos ataques se utilizan, para todo, desde el robo de datos a la desfiguración de sitios o la distribución de malware. CSP proporciona un conjunto de cabeceras HTTP estándar que permiten a los propietarios de sitios web declarar las fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página. Los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustables como applets Java, ActiveX y archivos de audio y vídeo.
URL	http://localhost:3000
Nombre del Nodo	http://localhost:3000
Método	GET
Ataque	
Evidencia	default-src 'self' 'unsafe-inline';base-uri 'self';font-src 'self' 'unsafe-inline';form-action 'self';frame-ancestors 'none';img-src 'self' data:;object-src 'none';script-src 'self' 'unsafe-inline';script-src-attr 'unsafe-inline';style-src 'self' 'unsafe-inline';upgrade-insecure-requests;connect-src 'self'
Otra información	script-src incluye unsafe-inline.
URL	http://localhost:3000/login/login.html
Nombre del Nodo	http://localhost:3000/login/login.html
Método	GET
Ataque	
Evidencia	default-src 'self' 'unsafe-inline';base-uri 'self';font-src 'self' 'unsafe-inline';form-action 'self';frame-ancestors 'none';img-src 'self' data:;object-src 'none';script-src 'self' 'unsafe-inline';script-src-attr 'unsafe-inline';style-src 'self' 'unsafe-inline';upgrade-insecure-requests;connect-src 'self'
Otra información	script-src incluye unsafe-inline.
URL	http://localhost:3000/registro/registro.html
Nombre del Nodo	http://localhost:3000/registro/registro.html
Método	GET
Ataque	
Evidencia	default-src 'self' 'unsafe-inline';base-uri 'self';font-src 'self' 'unsafe-inline';form-action 'self';frame-ancestors 'none';img-src 'self' data:;object-src 'none';script-src 'self' 'unsafe-inline';script-src-attr 'unsafe-inline';style-src 'self' 'unsafe-inline';upgrade-insecure-requests;connect-src 'self'
Otra información	script-src incluye unsafe-inline.
Instancia	3
Solución	Asegúrese de que su servidor web, servidor de aplicación, balanceador de carga, etc. está configurado apropiadamente para establecer la cabecera de Política de Seguridad de Contenido.
Referencia	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15

Plugin Id	10055

Medio	**CSP: style-src unsafe-inline**
Descripción	Content Security Policy (CSP) es una capa de seguridad añadida que ayuda a detectar y mitigar ciertos tipos de ataques. Incluyendo (pero no limitado a) Cross Site Scripting (XSS), y ataques de inyección de datos. Estos ataques se utilizan, para todo, desde el robo de datos a la desfiguración de sitios o la distribución de malware. CSP proporciona un conjunto de cabeceras HTTP estándar que permiten a los propietarios de sitios web declarar las fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página. Los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustables como applets Java, ActiveX y archivos de audio y vídeo.
URL	http://localhost:3000
Nombre del Nodo	http://localhost:3000
Método	GET
Ataque	
Evidencia	default-src 'self' 'unsafe-inline';base-uri 'self';font-src 'self' 'unsafe-inline';form-action 'self';frame-ancestors 'none';img-src 'self' data:;object-src 'none';script-src 'self' 'unsafe-inline';script-src-attr 'unsafe-inline';style-src 'self' 'unsafe-inline';upgrade-insecure-requests;connect-src 'self'
Otra información	style-src incluye unsafe-inline.
URL	http://localhost:3000/login/login.html
Nombre del Nodo	http://localhost:3000/login/login.html
Método	GET
Ataque	
Evidencia	default-src 'self' 'unsafe-inline';base-uri 'self';font-src 'self' 'unsafe-inline';form-action 'self';frame-ancestors 'none';img-src 'self' data:;object-src 'none';script-src 'self' 'unsafe-inline';script-src-attr 'unsafe-inline';style-src 'self' 'unsafe-inline';upgrade-insecure-requests;connect-src 'self'
Otra información	style-src incluye unsafe-inline.
URL	http://localhost:3000/registro/registro.html
Nombre del Nodo	http://localhost:3000/registro/registro.html
Método	GET
Ataque	
Evidencia	default-src 'self' 'unsafe-inline';base-uri 'self';font-src 'self' 'unsafe-inline';form-action 'self';frame-ancestors 'none';img-src 'self' data:;object-src 'none';script-src 'self' 'unsafe-inline';script-src-attr 'unsafe-inline';style-src 'self' 'unsafe-inline';upgrade-insecure-requests;connect-src 'self'
Otra información	style-src incluye unsafe-inline.
Instancia	3
Solución	Asegúrese de que su servidor web, servidor de aplicación, balanceador de carga, etc. está configurado apropiadamente para establecer la cabecera de Política de Seguridad de Contenido.
Referencia	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

CWE Id	693
WASC Id	15
Plugin Id	10055